# SIMATS ENGINEERING

**CSA6303 – Threat Intelligence and Network Security**

**A1 – Threat Intelligence Report**

*Assessment Submission*

| | | | |
|---|---|---|---|
| **Subject** | Threat Intelligence | **Total Marks** | 50 |
| **Questions** | 10 (all compulsory) | **Marks per Question** | 5 |
| **Reg. No** | 192465058 | **Name** | Dusyaant R |
| **Faculty** | Dr. V. Parthipan | **Slot** | A |

*Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.*

**Code of Conduct**

*I, Dusyaant R (Reg. No: 192465058), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

**Signature of Student:** _____

**Date:** 28 October 2026

---

## Q1. Malware

**Definition.** Malware (malicious software) is any program or code deliberately designed to infiltrate, damage, disrupt or gain unauthorised access to a computer system, network or data without the owner's consent.

| Type | How it spreads | Impact on the victim |
|---|---|---|
| **Virus** | Attaches itself to a legitimate file or program and spreads when the infected host is executed, shared through email attachments, USB drives or downloads. | Corrupts or deletes files and degrades system performance. |

| Type | How it spreads | Impact on the victim |
|---|---|---|
| **Worm** | Self-replicates and propagates over networks on its own by exploiting vulnerabilities (e.g., WannaCry using the SMB flaw), with no user action needed. | Consumes bandwidth and resources, causing network slowdowns or outages. |
| **Trojan** | Disguised as legitimate software (cracked apps, fake installers, malicious attachments); installed by the user unknowingly. It does not self-replicate. | Opens a backdoor for attackers, enabling data theft or remote control. |
| **Ransomware** | Delivered through phishing emails, malicious downloads or exploited services (e.g., exposed RDP). | Encrypts files and demands payment for the key, causing data loss and business downtime. |
| **Spyware** | Bundled with free software, or installed via drive-by downloads and malicious links. | Secretly records keystrokes, credentials and browsing activity, leading to identity theft. |

# Q2. Phishing

**How a phishing attack is carried out.**

1. **Reconnaissance:** the attacker selects a target and gathers information (email addresses, brand details).
2. **Lure creation:** a convincing email, SMS or website is crafted that imitates a trusted entity such as a bank or employer.
3. **Delivery:** the message creates urgency ("account suspended") and carries a malicious link or attachment.
4. **Exploitation:** the victim clicks, lands on a fake login page and enters credentials, or opens an attachment that installs malware.
5. **Harvesting and misuse:** stolen credentials or data are used for fraud, account takeover or further intrusion.

**Differences between variants.**

| Variant | Target | Method |
|---|---|---|
| **Spear phishing** | A specific individual or small group | Personalised email using details about the victim (name, role, colleagues). |

| Variant | Target | Method |
|---|---|---|
| **Whaling** | Senior executives (CEO, CFO) | Highly targeted and polished messages, such as fake legal notices or wire-transfer requests, aimed at high-value authority. |
| **Vishing** | Any individual | Voice phishing by phone call or voicemail, impersonating a bank or support staff to obtain OTPs or card details. |

**Three measures to reduce phishing risk.**

1. Regular security-awareness training and simulated phishing exercises for staff.
2. Email security controls: spam and anti-phishing filters, SPF, DKIM and DMARC, and link or attachment sandboxing.
3. Multi-factor authentication (MFA) so that stolen passwords alone are not enough to gain access, together with a clear process for reporting suspicious messages.

## Q3. DoS and DDoS

**Distinction.**

| Aspect | DoS | DDoS |
|---|---|---|
| Source | Single machine or connection | Many compromised machines (botnet) across locations |
| Scale | Limited bandwidth and volume | Very large volume, often hundreds of Gbps or more |
| Detection and blocking | Easy: block the single source IP | Hard: traffic comes from thousands of legitimate-looking IPs |
| Goal | Make a service unavailable to legitimate users | Same, but with greater impact |

**Working of a SYN flood.** A normal TCP connection uses a three-way handshake (SYN, SYN-ACK, ACK). In a SYN flood, the attacker sends a large number of SYN packets, often with spoofed source IPs. The server replies with SYN-ACK and holds a half-open connection in its backlog queue while waiting for the final ACK, which never arrives. The queue fills up, and the server can no longer accept legitimate connection requests, so the service becomes unavailable.

**Two mitigation techniques.**

1. **SYN cookies:** the server encodes connection state in the SYN-ACK sequence number instead of storing half-open entries, so the backlog cannot be exhausted.
2. **Rate limiting and filtering / CDN scrubbing:** limit SYN packets per source, and route traffic through a CDN or scrubbing service that absorbs and filters attack traffic (blackhole routing is a last resort).

## Q4. Man-in-the-Middle Attacks

**Definition.** A Man-in-the-Middle (MITM) attack occurs when an attacker secretly positions themselves between two communicating parties, intercepting and possibly altering the data exchanged, while both parties believe they are communicating directly with each other.

**Two techniques.**

1. **ARP poisoning:** on a local network, the attacker sends forged ARP replies associating their MAC address with the gateway's IP address. Victims' traffic is then sent to the attacker, who inspects it and forwards it onward.
2. **Rogue Wi-Fi access point (evil twin):** the attacker sets up a fake hotspot with a familiar name (e.g., "Free_Airport_WiFi"). Users who connect have all their traffic routed through the attacker's device. (SSL stripping is similar in effect: HTTPS links are downgraded to HTTP so traffic is readable.)

**How encryption helps defend.**

- **TLS/HTTPS** encrypts data in transit, so intercepted traffic is unreadable without the session keys.
- **Certificate validation** lets the client verify the server's identity, so a fake server is detected.
- **HSTS** forces browsers to use HTTPS only, preventing SSL stripping.
- **VPNs** create an encrypted tunnel, protecting traffic even on untrusted networks.

## Q5. Spoofing and Sniffing

**Comparison.**

| Aspect | Spoofing | Sniffing |
|---|---|---|
| Nature | Active: forging identity (IP, MAC, email, DNS) | Passive: capturing and monitoring network traffic |

| Aspect | Spoofing | Sniffing |
|---|---|---|
| Purpose | Impersonate a trusted source, bypass controls | Eavesdrop on data such as credentials or sessions |
| Detectability | Often detectable through anomalies | Hard to detect, since it only listens |

**IP spoofing.** The attacker forges the source IP address in packet headers to hide their identity or impersonate a trusted host. *Example:* In a DDoS reflection attack, the attacker spoofs the victim's IP in requests to open DNS servers, which then flood the victim with responses.

**ARP spoofing.** The attacker sends fake ARP messages to link their MAC address with the IP of another host (such as the default gateway). *Example:* On a office LAN, the attacker poisons the ARP caches of users so that their traffic passes through the attacker's machine, enabling interception.

**Packet sniffers (e.g., Wireshark).**

- *Malicious use:* capturing unencrypted credentials, session cookies and sensitive data on shared or insecure networks.
- *Legitimate use:* network troubleshooting, performance analysis, protocol debugging, and detecting intrusions or malware traffic during security investigations.

**Countermeasure:** use end-to-end encryption (HTTPS, SSH, VPN) so captured packets are unreadable; dynamic ARP inspection and static ARP entries help against ARP spoofing.

## Q6. Vulnerability Assessment

**Vulnerability assessment (VA)** is the systematic process of identifying, classifying and prioritising security weaknesses in systems, applications and networks.

**Main phases.**

1. **Asset discovery:** identify all hosts, devices, applications and services in scope.
2. **Vulnerability scanning:** run automated tools to detect known flaws, misconfigurations and missing patches.
3. **Analysis and prioritisation:** verify results, remove false positives and rank findings by severity and business impact.
4. **Reporting:** document findings, evidence and risk ratings with recommendations.
5. **Remediation and re-scan:** apply patches or fixes, then re-test to confirm closure.

**Vulnerability assessment vs penetration testing.**

| Aspect | Vulnerability Assessment | Penetration Testing |
|---|---|---|
| Goal | Find and list as many weaknesses as possible | Exploit weaknesses to show real-world impact |
| Approach | Mostly automated, broad coverage | Mostly manual, targeted and in depth |
| Exploitation | Generally no exploitation | Controlled exploitation is performed |
| Output | Prioritised list of vulnerabilities | Proof of compromise and attack paths |
| Frequency | Regular and continuous | Periodic (e.g., annually) |

**Two commonly used scanning tools:** Nessus and OpenVAS (Qualys is another widely used option).

## Q7. Vulnerability Scoring

**CVE (Common Vulnerabilities and Exposures)** is a public catalogue that assigns a unique identifier (e.g., CVE-2021-44228) to each publicly disclosed vulnerability, giving everyone a common name to refer to the same flaw.

**CVSS (Common Vulnerability Scoring System)** is an open standard that rates the severity of a vulnerability on a scale of 0.0 to 10.0, based on metrics such as attack vector, complexity, privileges required, user interaction and impact on confidentiality, integrity and availability.

| Score | Severity |
|---|---|
| 0.0 | None |
| 0.1 – 3.9 | Low |
| 4.0 – 6.9 | Medium |
| 7.0 – 8.9 | High |
| 9.0 – 10.0 | Critical |

**Role in prioritisation.** CVSS provides a consistent, objective way to compare vulnerabilities, so teams can fix Critical and High issues first and allocate limited time and resources effectively.

**Why a high CVSS score alone is not enough.** Context matters:

- **Exploitability:** is there a public exploit, or is it being actively exploited in the wild?
- **Asset criticality:** a medium flaw on a crown-jewel server may outrank a high flaw on an isolated test machine.
- **Exposure:** internet-facing systems carry more risk than internal ones.
- **Compensating controls:** firewalls, WAF or segmentation may reduce actual risk.

## Q8. Threat Data Sources and OSINT

**Main sources of threat data.**

| Category | Description | Examples |
|---|---|---|
| **Internal** | Data generated within the organisation | Firewall, IDS/IPS and server logs, SIEM alerts, past incident records |
| **External** | Data from outside parties and the wider community | Government CERT advisories, ISACs, vendor bulletins, industry peers |
| **Open-source** | Freely available public information | Public blogs, forums, social media, vulnerability databases, public threat feeds |
| **Commercial** | Paid, curated intelligence from vendors | Recorded Future, CrowdStrike, Mandiant subscriptions |

**OSINT (Open-Source Intelligence)** is intelligence collected and analysed from publicly available sources to support security decisions and understand threats.

**Three OSINT sources/tools.**

1. **Shodan:** search engine for internet-connected devices, used to find exposed services and misconfigured systems.
2. **VirusTotal:** analyses files, URLs and domains against many antivirus engines and reputation sources to check whether they are malicious.
3. **WHOIS and DNS lookups:** reveal domain registration details, name servers and infrastructure linked to attacker campaigns. (Social media and dark-web monitoring are other common sources.)

## Q9. Indicators of Compromise (IoCs)

**Definition.** Indicators of Compromise (IoCs) are pieces of forensic evidence or artefacts that suggest a system or network has been breached or is under attack.

| Category | Description | Two examples |
|---|---|---|
| **Network-based** | Observed in network traffic | Connections to a known malicious IP address or domain; unusual outbound traffic or beaconing to a command-and-control server |
| **Host-based** | Observed on an endpoint or server | New or unknown user accounts or services; suspicious registry keys, scheduled tasks or processes |
| **File-based** | Properties of malicious files | Known malicious file hash (MD5/SHA-256); suspicious file names or paths and unexpected changes to system files |

**Use during incident response.**

- **Detection:** IoCs are loaded into SIEM, IDS and EDR tools to automatically detect matching activity.
- **Scoping and containment:** teams search logs and endpoints for the same indicators to find all affected systems, then isolate them and block malicious IPs, domains and hashes.
- **Eradication and recovery:** IoCs help verify the threat is fully removed, and are shared with partners to prevent further spread.

## Q10. Threat Feeds

**Definition.** A threat intelligence feed is a continuously updated stream of data about current and emerging threats, such as malicious IP addresses, domains, URLs, file hashes and attacker techniques. Security tools consume it to detect and block threats.

**Common formats and sharing standards.**

- **STIX (Structured Threat Information eXpression):** a standardised language for describing threat information such as indicators, malware, threat actors and campaigns.
- **TAXII (Trusted Automated eXchange of Intelligence Information):** a protocol for securely exchanging STIX data between organisations over HTTPS.
- Other formats include CSV, JSON, XML and OpenIOC.

**Advantages.**

1. Provides timely, automated awareness of new threats, enabling faster detection and blocking.

2. Enriches security alerts with context and removes the need to research every indicator manually.

**Limitations.**

1. Can produce false positives and noise, and indicators go stale quickly.
2. Quality and relevance vary; feeds may lack context for the organisation's own environment and may require analyst effort to integrate and tune.

**Two example feeds:** AlienVault OTX and abuse.ch (MISP is another popular sharing platform).

---

*End of Assessment*